

PRODUCT REQUIREMENTS DOCUMENT

Sales & Tender Management System

Version 1.0 | Juni 2025

Klasifikasi: Confidential / Internal

Disiapkan oleh: Tim Produk (BA + QA + SE)

1. Executive Summary

Sales & Tender Management System (STMS) adalah platform manajemen internal berbasis web yang dirancang untuk mengotomasi dan menstandarisasi proses bisnis dari identifikasi prospek penjualan hingga penyelesaian proyek tender. Sistem ini menggantikan proses manual yang sebelumnya tersebar di berbagai media (email, spreadsheet, dokumen fisik) menjadi satu alur digital yang terintegrasi, terotomasi, dan dapat diaudit.

Sistem dibangun dengan arsitektur modern: frontend React + TypeScript + Tailwind CSS, backend PHP REST API, database MySQL, dan dijalankan dalam lingkungan containerized menggunakan Docker. Seluruh stakeholder internal (Cabang, Project Manager, Departemen, Management) berkolaborasi dalam satu platform dengan peran dan hak akses yang terdefinisi jelas.

Dokumen PRD ini disusun dengan pendekatan kritis dari perspektif Business Analyst, Quality Assurance, dan Software Engineer. Informasi awal yang diterima diperlakukan sebagai referensi dan bukan spesifikasi final; sejumlah gap, inkonsistensi, dan peluang perbaikan telah diidentifikasi dan dibahas di dalam dokumen ini.

2. Problem Statement

2.1 Kondisi Saat Ini (As-Is)

- Proses tender dan prospek dikelola secara manual menggunakan email, spreadsheet, dan dokumen fisik yang tersebar.
- Tidak ada visibility real-time terhadap status proyek; informasi harus diminta secara manual ke setiap pihak.
- Approval dilakukan via email/chat tanpa alur formal, histori persetujuan sulit ditelusuri, dan tidak ada enforcement deadline.
- Koordinasi antar departemen (Cabang, PM, Departemen Teknis, Management) tidak terstruktur, menimbulkan delay dan miskomunikasi.
- Dokumen tender (RKS, LPHS, SIOS, penawaran harga) disimpan di berbagai lokasi tanpa versioning.
- Tidak ada laporan agregat otomatis; dashboard performa harus dibuat secara manual periodik.

2.2 Dampak Bisnis

- Win rate tender tidak terukur secara akurat dan tepat waktu.
- Deadline tender terlewat akibat keterlambatan koordinasi approval.
- Risiko compliance: dokumen approval tidak lengkap saat audit.
- Beban administrasi tinggi pada staf cabang dan PM.

3. Business Goals

#	Tujuan Bisnis	Indikator Keberhasilan (KPI)	Target
B G - 0 1	Digitalisasi end-to-end alur prospek dan tender	Eliminasi proses manual berbasis email/spreadsheet untuk approval	100% dalam 3 bulan
B G - 0 2	Meningkatkan kecepatan proses approval	Rata-rata waktu per siklus approval	< 2 hari kerja
B G - 0 3	Meningkatkan visibilitas status proyek lintas departemen	% proyek yang status real-time-nya tersedia di dashboard	100%
B G - 0 4	Meningkatkan akurasi pelaporan win/loss tender	Ketersediaan laporan win rate bulanan otomatis	Tersedia T+1 hari
B G - 0 5	Memastikan compliance dokumen dan audit trail	% approval yang memiliki histori lengkap	100%
B G - 0 6	Skalabilitas sistem untuk pertumbuhan volume proyek	Sistem mampu menangani 10x volume proyek saat ini	Tanpa degradasi performa

4. User Personas

4.1 Staf Cabang (Role: cabang)

- Profil: Staf operasional di kantor cabang yang bertanggung jawab menginput data prospek, mengisi data tender (RKS), melaporkan harga penawaran, kompetitor, dan hasil tender.
- Kebutuhan: Interface sederhana untuk input data, upload dokumen, dan tracking status proyek yang ditangani cabang tersebut.
- Pain Point: Sering menunggu approval tanpa informasi kapan dan mengapa ada revisi. Tidak tahu urutan langkah berikutnya.
- Ekspektasi: Notifikasi real-time saat ada permintaan revisi atau approval selesai.

4.2 Project Manager (Role: pm)

- Profil: PM bertanggung jawab mengawasi kualitas dokumen RKS, memastikan pertanyaan teknis terjawab, dan memberikan persetujuan sebelum eskalasi ke departemen/management.
- Kebutuhan: Kemampuan mereview dan memberikan catatan revisi yang terstruktur, melihat semua proyek yang perlu approval-nya.
- Pain Point: Saat ini tidak ada antrean pekerjaan yang jelas; PM harus mengingat atau dicari oleh cabang.
- Ekspektasi: Dashboard antrean approval, notifikasi push/email saat ada item pending.

4.3 Staf Departemen (Role: department)

- Profil: Spesialis teknis per departemen (misal: Engineering, Legal, Finance) yang mereview aspek LPHS/SIOS sesuai bidangnya.
- Kebutuhan: Akses hanya ke proyek yang relevan dengan departemennya, kemampuan approve/revisi dengan catatan.
- Pain Point: Tidak tahu apakah dokumen sudah final atau masih draft saat diminta review.
- Ekspektasi: Versi dokumen yang jelas, riwayat perubahan, dan status dokumen (draft/final).

4.4 Management (Role: management)

- Profil: Pimpinan yang memberikan persetujuan akhir pada LPHS/SIOS setelah semua departemen setuju.
- Kebutuhan: Ringkasan eksekutif proyek, status approval semua departemen, dan kemampuan approve/revisi dengan satu tindakan.
- Pain Point: Harus mengumpulkan informasi dari berbagai sumber sebelum membuat keputusan.
- Ekspektasi: One-page summary per proyek dengan semua approval status terkumpul.

4.5 Administrator (Role: admin)

- Profil: IT/Admin yang mengelola master data (users, customers, departments, pertanyaan), konfigurasi sistem, dan troubleshooting.
- Kebutuhan: CRUD master data, manajemen user dan role, akses audit log, monitoring sistem.
- Pain Point: Tidak ada antarmuka admin yang terpusat saat ini.
- Ekspektasi: Admin panel lengkap dengan kemampuan impersonate user untuk debugging.

5. Scope

5.1 In Scope

- Manajemen prospek: CRUD, alur approval PM, revisi, dan eskalasi ke proyek.
- Manajemen proyek tender dan non-tender: alur status dari created hingga selesai.
- Modul RKS: input data tender, upload dokumen, pengisian pertanyaan master, review PM.
- Modul LPHS/SIOS: draft upload, approval multi-departemen, approval PM dan management.
- Modul Harga & Kompetitor: input penawaran harga, data kompetitor.
- Modul Pemenang & Delivery: pencatatan hasil tender dan target delivery.
- Approval workflow multi-role dengan histori keputusan.
- Timeline event per proyek.
- Audit log seluruh aktivitas.
- Dashboard ringkasan dan KPI.
- Master data: users, customers, departments, pertanyaan.
- Upload dan download dokumen.
- Sistem notifikasi in-app.
- Containerization menggunakan Docker (Docker Compose).
- Role-based access control (RBAC).

5.2 Out of Scope (Fase Pertama)

- Integrasi dengan sistem ERP/CRM eksternal (misalnya SAP, Salesforce).
- Aplikasi mobile native (iOS/Android); hanya responsif di browser.
- Notifikasi email/SMS/push eksternal (fase kedua).
- e-Signature terintegrasi.
- Modul keuangan/invoicing.
- Pelaporan BI lanjutan (Power BI/Tableau integration).
- Single Sign-On (SSO) dengan Active Directory (fase kedua).

6. User Journey

6.1 Journey: Prospek → Proyek

1. Staf Cabang membuat prospek baru: mengisi nama, customer, deskripsi, dan checklist pertanyaan awal.
2. Cabang mengajukan prospek ke PM (status: waiting_pm_approval).
3. PM menerima notifikasi dan mereview prospek.
4. PM Approve → Prospek berstatus approved → Cabang dapat membuat Project dari prospek ini.
5. PM Revision → PM mengisi pertanyaan review → Cabang menerima notifikasi dan menjawab → Cabang kirim kembali ke PM.

6.2 Journey: Tender (created → selesai)

6. Cabang mengisi RKS: nomor tender, nama, customer, deadline, upload dokumen, jawab pertanyaan master.
7. Cabang submit ke Review Departemen (status: submit_rks).
8. PM mereview RKS: jika ada pertanyaan yang belum lengkap, PM kirim revisi ke Cabang (status: revision). Cabang menjawab dan kirim kembali.
9. PM Approve RKS → status: review_department. Departemen-departemen yang ditentukan mereview dan approve.
10. Setelah PM Approve → masuk ke fase LPHS/SIOS (status: lphs_sios).
11. Cabang memilih departemen yang harus approve LPHS/SIOS, upload draft dokumen.
12. PM approve/revisi draft → Departemen-departemen approve/revisi per departemen → Management approve (syarat: semua dept sudah approve).
13. Management Approve LPHS → status: submit_harga.
14. Cabang mengisi harga penawaran dan data kompetitor.
15. Hasil tender diumumkan → Cabang input pemenang (menang/kalah) dan upload dokumen pendukung (status: pengumuman_pemenang).
16. Cabang input target delivery → status: target_delivery.
17. Target delivery tercapai → status: selesai.

6.3 Journey: Non-Tender / Prospecting

18. Cabang membuat proyek berstatus created dengan type prospecting.
19. Alur yang dilewati: created → submit_harga → pengumuman_pemenang → target_delivery → selesai.
20. Tahap RKS, review departemen, dan LPHS/SIOS tidak berlaku.

7. Functional Requirements

ID	Requirement	Priority	Alasan
FR-001	Sistem menyediakan autentikasi username/password dengan session management yang aman	Must Have	Keamanan akses dasar
FR-002	Role-based access control (RBAC): cabang, pm, department, management, admin	Must Have	Setiap role hanya mengakses fitur yang relevan
FR-003	Logout otomatis setelah idle 30 menit	Must Have	Keamanan sesi
FR-004	Admin dapat membuat, menonaktifkan, dan mengubah role user	Must Have	Manajemen user lifecycle
FR-010	Cabang dapat membuat prospek dengan data: nama, customer, deskripsi, checklist pertanyaan	Must Have	Entry point alur bisnis
FR-011	Cabang dapat submit prospek ke PM untuk direview	Must Have	Trigger alur approval
FR-012	PM dapat approve atau memberikan revisi prospek dengan catatan terstruktur	Must Have	Gatekeeper kualitas
FR-013	Cabang dapat menjawab pertanyaan revisi PM dan re-submit prospek	Must Have	Menutup loop revisi
FR-014	Prospek yang approved dapat dikonversi menjadi proyek	Must Have	Hubungan prospek-proyek
FR-015	Cabang hanya dapat melihat prospek milik cabangnya sendiri	Must Have	Data isolation per cabang
FR-020	Sistem mendukung dua tipe proyek: tender dan prospecting dengan alur status berbeda	Must Have	Core bisnis
FR-021	Stepper visual menampilkan posisi proyek dalam alur dan langkah berikutnya	Must Have	UX clarity
FR-022	Setiap perubahan status proyek wajib dicatat di timeline_events	Must Have	Audit trail & traceability
FR-030	Cabang dapat mengisi data RKS: nomor tender, deadline, upload dokumen, jawab pertanyaan master	Must Have	Data tender lengkap
FR-031	Validasi: nomor tender harus unik per customer, deadline tidak boleh di masa lalu	Must Have	Integritas data
FR-032	PM dapat submit pertanyaan review dengan marking 'harus dijawab' per pertanyaan	Must Have	Review terstruktur

ID	Requirement	Priority	Alasan
FR-033	PM approve RKS hanya jika semua pertanyaan review sudah terjawab	Must Have	Business rule enforcement
FR-040	Cabang memilih subset departemen yang wajib approve LPHS/SIOS per proyek	Must Have	Fleksibilitas per proyek
FR-041	PM dapat approve/revisi draft LPHS/SIOS	Must Have	Layer review PM
FR-042	Setiap departemen yang terpilih dapat approve/revisi dengan catatan	Must Have	Review teknis per dept
FR-043	Management approve hanya diizinkan jika PM dan semua dept sudah approve	Must Have	Enforcement urutan approval
FR-044	Setelah management approve LPHS → status otomatis pindah ke submit_harga	Must Have	State transition
FR-050	Cabang mengisi harga penawaran dengan: nominal, margin, catatan, file/link pendukung	Must Have	Data penawaran
FR-051	Cabang mengisi daftar kompetitor per proyek	Should Have	Analisis kompetitif
FR-060	Cabang mencatat hasil tender: menang atau kalah, dengan dokumen pendukung	Must Have	Penutupan siklus tender
FR-061	Jika kalah: cabang mengisi alasan kekalahan (bidding too high, competitor advantage, dll.)	Should Have	Data analisis untuk perbaikan masa depan
FR-062	Cabang mengisi target delivery: tanggal mulai, selesai, keterangan	Must Have	Perencanaan pasca-menang
FR-070	Upload dokumen dengan validasi tipe file (PDF, DOCX, XLSX, JPEG, PNG) dan ukuran maksimal	Must Have	Keamanan upload
FR-071	Dokumen yang diupload dapat didownload oleh semua role yang memiliki akses ke proyek	Must Have	Akses dokumen
FR-072	Versioning dokumen: jika ada upload ulang, versi sebelumnya tetap tersimpan	Should Have	Traceability dokumen
FR-080	Dashboard menampilkan: jumlah proyek per status, win rate, nilai pipeline, proyek approaching deadline	Must Have	Visibilitas eksekutif
FR-081	Dashboard dapat difilter per cabang (untuk management dan admin)	Should Have	Analisis per cabang
FR-082	Grafik trend win/loss per periode (bulanan/kuartalan)	Should Have	Insight bisnis

ID	Requirement	Priority	Alasan
FR-090	Notifikasi in-app saat ada perubahan status yang memerlukan aksi dari user yang sedang login	Must Have	Mengurangi keterlambatan response
FR-091	Badge counter pada menu menampilkan jumlah item pending aksi	Should Have	UX awareness
FR-092	Notifikasi email untuk deadline approval yang mendekati (T-2 hari)	Could Have	Fase 2: external notif
FR-100	Admin CRUD: users, customers, departments, pertanyaan master	Must Have	Manajemen referensi data
FR-101	Pertanyaan master mendukung tipe: text, textarea, radio, checkbox, select	Must Have	Fleksibilitas form
FR-102	Migrasi question type definitions dari localStorage ke database	Must Have	Bug fix: data tidak persist antar session
FR-110	Setiap aksi CRUD dan status change dicatat di audit_logs dengan user, timestamp, dan payload	Must Have	Compliance & forensik
FR-111	Admin dapat melihat dan mengekspor audit log	Should Have	Investigasi dan compliance
FR-120	Seluruh komponen (frontend, backend, DB) dapat dijalankan dengan satu perintah docker-compose up	Must Have	Kemudahan deployment dan onboarding
FR-121	Environment variables dikelola melalui .env file, tidak hardcode di source code	Must Have	Keamanan konfigurasi
FR-122	Volume Docker untuk persistensi data MySQL dan file upload	Must Have	Data tidak hilang saat container restart

8. Detailed Feature Specification

8.1 Fitur: Autentikasi & Manajemen Session

Objective

Memastikan hanya pengguna terautentikasi yang dapat mengakses sistem, dengan session yang aman dan role yang tepat.

User Flow

21. User membuka aplikasi → redirect ke halaman login jika belum terautentikasi.
22. User memasukkan username dan password → klik Login.
23. Backend memvalidasi kredensial → mengembalikan session token (JWT atau session cookie HttpOnly).
24. Frontend menyimpan token dan memuat data awal sesuai role.
25. Setelah idle 30 menit → session expired, user di-redirect ke login.

Business Rules

- Password minimal 8 karakter, mengandung huruf besar, huruf kecil, dan angka.
- Akun dinonaktifkan (bukan dihapus) oleh admin; user yang dinonaktifkan tidak bisa login.
- Setiap login berhasil/gagal dicatat di audit_log.
- Setelah 5 kali gagal login, akun terkunci sementara selama 15 menit.

Validation Rules

- Username: required, alphanumeric, 3–50 karakter.
- Password: required, minimal 8 karakter, tidak ditampilkan plaintext.

Edge Cases

- User mencoba akses URL langsung tanpa autentikasi → redirect ke login dengan pesan 'Sesi tidak aktif'.
- Dua session aktif bersamaan untuk user yang sama → session terlama diinvalidasi.
- Admin menonaktifkan user yang sedang online → session diinvalidasi dalam 5 menit.

Acceptance Criteria

- Given user belum login, When mengakses halaman manapun, Then di-redirect ke halaman login.
- Given kredensial valid, When login, Then session dimulai dan user diarahkan ke dashboard sesuai role.
- Given idle 30 menit, When mencoba melakukan aksi, Then session expired dan di-redirect ke login.
- Given 5 kali gagal login, When mencoba login kembali, Then tampil pesan 'Akun terkunci, coba lagi dalam 15 menit'.

8.2 Fitur: Manajemen Prospek

Objective

Memungkinkan staf cabang mendaftarkan peluang bisnis baru dan mendapatkan persetujuan dari PM sebelum diproses lebih lanjut.

User Flow

26. Cabang membuka halaman Prospek → klik 'Tambah Prospek'.
27. Cabang mengisi form: nama prospek, customer (dari master), deskripsi, checklist pertanyaan.
28. Cabang menyimpan draft atau langsung submit ke PM.
29. [PM] Menerima notifikasi → membuka daftar prospek pending → mereview.
30. [PM] Approve → prospek berstatus 'approved'. [PM] Revision → mengisi pertanyaan/catatan, submit revision.
31. [Cabang] Jika revision → menerima notifikasi → membuka prospek → menjawab → re-submit ke PM.
32. [Cabang] Dari prospek approved → dapat create Project.

Business Rules

- Cabang hanya bisa melihat dan mengedit prospek yang dibuat oleh cabang yang sama.
- PM dapat melihat semua prospek dari semua cabang.
- Prospek tidak bisa diedit setelah status `waiting_pm_approval` kecuali statusnya kembali ke `revision`.
- Penghapusan prospek yang sudah memiliki proyek terkait harus menghapus proyek tersebut juga (cascade delete dengan konfirmasi eksplisit).

Validation Rules

- Nama prospek: required, 3–200 karakter.
- Customer: required, harus dari master customer (foreign key).
- Deskripsi: optional, max 2000 karakter.
- Pertanyaan checklist: semua pertanyaan bertipe required harus diisi sebelum submit.

Edge Cases

- Customer dihapus dari master setelah prospek dibuat → prospek tetap valid, customer ditampilkan sebagai '[Dihapus]'.
- PM mengubah role menjadi bukan PM saat ada prospek pending di antreanya → admin atau PM lain harus bisa re-assign.
- Cabang menghapus prospek yang sedang di-review PM → sistem mengirim notifikasi ke PM bahwa item dihapus.

Acceptance Criteria

- Given cabang membuka halaman prospek, When login sebagai cabang A, Then hanya prospek milik cabang A yang tampil.
- Given semua pertanyaan required belum diisi, When klik Submit ke PM, Then tampil validasi error dan submit diblokir.
- Given PM memberikan revisi, When cabang membuka prospek, Then pertanyaan revisi tampil jelas dengan catatan PM.
- Given prospek statusnya approved, When cabang klik 'Buat Proyek', Then proyek baru terbuat dengan data prospek sebagai referensi.

8.3 Fitur: Alur Tender End-to-End (RKS → LPHS → Harga → Hasil)

Objective

Mengotomasi dan menegakkan alur approval tender yang melibatkan banyak pihak (Cabang, PM, Departemen, Management) dengan state machine yang ketat.

State Machine Tender

Status Dari	Status Ke	Trigger	Actor
created	submit_rks	Cabang submit RKS	Cabang
submit_rks	revision	PM kirim revisi RKS	PM
revision	submit_rks	Cabang re-submit setelah revisi	Cabang
submit_rks	review_departmen	PM approve RKS (semua jawaban terisi)	PM
review_departmen	lphs_sios	Dept approval selesai + PM approve	PM
lphs_sios	revision	PM atau Management revision LPHS	PM / Mgmt
lphs_sios	submit_harga	Management approve LPHS (semua dept approve)	Management
submit_harga	pengumuman_pemenang	Cabang submit pemenang	Cabang
pengumuman_pemenang	target_delivery	Cabang input target delivery	Cabang
target_delivery	selesai	Cabang konfirmasi selesai	Cabang

Business Rules

- Transition status hanya bisa dilakukan oleh role yang berwenang (enforced di backend).
- Backend harus memvalidasi pre-condition sebelum setiap transition (misal: management_approve_lphs memastikan pmApproval = approved dan semua dept yang dipilih sudah approve).
- Setiap transition wajib membuat record di timeline_events dan approvals (jika merupakan keputusan approve/revisi).

Edge Cases

- Departemen yang sudah approve LPHS, kemudian PM memberikan revisi → status approval departemen direset.
- Deadline tender terlewat saat proyek masih dalam proses → sistem menampilkan warning merah, bukan memblokir alur.
- Proyek dihapus saat masih dalam review departemen → notifikasi dikirim ke semua reviewer aktif.

Acceptance Criteria

- Given management mencoba approve LPHS sebelum semua dept approve, When klik Approve, Then backend menolak dengan error ""Semua departemen harus menyetujui terlebih dahulu"".
- Given proyek tender berhasil diselesaikan, When membuka timeline, Then seluruh histori status change tampil secara kronologis.

8.4 Fitur: Upload & Manajemen Dokumen

Objective

Menyediakan repositori dokumen terpusat untuk setiap proyek dengan keamanan dan traceability yang memadai.

Business Rules

- Tipe file yang diizinkan: PDF, DOCX, XLSX, JPEG, PNG.
- Ukuran file maksimum per upload: 25 MB.
- File disimpan di luar webroot (tidak dapat diakses langsung via URL) dan hanya dapat didownload melalui endpoint yang terautentikasi.
- Nama file disanitasi (no path traversal, no special characters berbahaya) sebelum disimpan.
- Setiap upload dan download dicatat di audit_log.

Validation Rules

- Validasi tipe file di sisi client (untuk UX) DAN server (untuk keamanan).
- Validasi ukuran file di kedua sisi.
- Validasi MIME type di server, bukan hanya ekstensi.

Edge Cases

- Upload file dengan nama yang sama → simpan dengan timestamp suffix, bukan overwrite.
- File yang diupload corrupt (truncated) → sistem mendeteksi dan menolak.
- User mengakses URL download file milik proyek yang bukan haknya → 403 Forbidden.

Acceptance Criteria

- Given user upload file .exe, Then sistem menolak dengan pesan 'Tipe file tidak diizinkan'.
- Given user upload file 30 MB, Then sistem menolak dengan pesan 'Ukuran file melebihi batas 25 MB'.
- Given user yang tidak berhak mencoba download dokumen via URL langsung, Then sistem mengembalikan 403.

8.5 Fitur: Dashboard & Laporan

Objective

Menyediakan visibilitas real-time dan agregat data proyek kepada semua stakeholder sesuai scope role masing-masing.

Konten Dashboard per Role

Role	Konten Dashboard
Cabang	Proyek aktif cabang, proyek approaching deadline (≤ 7 hari), win rate cabang saat ini
PM	Queue approval pending (prospek & RKS), proyek dalam review, statistik revisi vs approve
Department	Proyek yang membutuhkan review LPHS dari departemen ini, histori approval
Management	Pipeline value total, win rate keseluruhan, approval LPHS pending, proyek selesai bulan ini
Admin	Semua data lintas cabang, statistik user aktif, error log, system health

Acceptance Criteria

- Given login sebagai management, When membuka dashboard, Then tampil total nilai pipeline, win rate bulan ini, dan daftar approval LPHS pending.
- Given proyek memiliki deadline dalam 3 hari, When cabang membuka dashboard, Then proyek tersebut tampil dengan highlight merah di bagian 'Approaching Deadline'.

9. Non-Functional Requirements

9.1 Security

- Autentikasi: JWT dengan expiry 8 jam, atau session cookie HttpOnly + Secure + SameSite=Strict.
- Password hashing: bcrypt dengan cost factor minimal 12.
- HTTPS wajib di semua environment termasuk development (self-signed cert via Docker).
- Input sanitasi: semua input user divalidasi dan di-escape sebelum query DB (prepared statements, no raw SQL concatenation).
- SQL injection prevention: gunakan PDO prepared statements di seluruh backend PHP.
- XSS prevention: output escaping konsisten di frontend React dan response API.
- CSRF protection: gunakan CSRF token untuk semua mutasi (POST/PUT/DELETE).
- File upload: validasi MIME type server-side, simpan di luar webroot, scan antivirus jika memungkinkan.
- Rate limiting: API endpoint login dibatasi 10 request/menit per IP.
- RBAC enforcement di backend: setiap endpoint memvalidasi role dari session, tidak hanya dari client.
- Secrets (DB password, JWT secret) hanya dari environment variables, tidak dari source code.

9.2 Performance

- API response time: P95 < 500ms untuk GET list, P95 < 1000ms untuk operasi tulis.
- Dashboard load time: < 2 detik pada koneksi 10 Mbps.
- Upload file: mendukung file hingga 25 MB tanpa timeout (server timeout ≥ 60 detik).
- Database query: semua query dengan filter status/cabang/project menggunakan indeks yang tepat.
- Frontend: lazy loading per route, bundle split untuk mengurangi initial load.

9.3 Scalability

- Database connection pooling agar efisien di bawah beban tinggi.
- File storage didesain agar mudah dimigrasikan ke object storage (S3-compatible) di masa depan.
- Backend PHP didesain stateless agar mudah di-scale horizontal (tambah container).
- Docker Compose saat ini; arsitektur didesain agar kompatibel dengan migrasi ke Kubernetes jika skala bertambah.

9.4 Reliability

- Uptime target: 99.5% pada jam kerja (Senin–Jumat 08.00–18.00 WIB).
- Backup database otomatis harian dengan retensi 30 hari.
- Restore procedure terdokumentasi dan dites minimal kuartalan.
- Health check endpoint: GET /backend/health.php mengembalikan status DB dan disk.
- Graceful error handling: error 500 menampilkan pesan generik ke user, detail error hanya di log server.

9.5 Accessibility

- UI memenuhi WCAG 2.1 Level AA untuk elemen kritis (form, tombol, navigasi).
- Semua gambar/ikon memiliki alt text atau aria-label.
- Keyboard navigable untuk seluruh alur utama.
- Contrast ratio minimum 4.5:1 untuk teks normal.

9.6 Audit & Logging

- Semua login (berhasil/gagal), logout, dan perubahan password dicatat.
- Semua perubahan data (create, update, delete) dan perubahan status proyek/prospek dicatat dengan user, timestamp, IP, dan payload sebelum/sesudah.
- Semua upload dan download dokumen dicatat.
- Log error server disimpan di volume Docker terpisah dengan rotasi harian.
- Audit log tidak dapat diedit atau dihapus oleh siapapun (append-only).
- Admin dapat mengekspor audit log dalam format CSV.

10. Data Model Recommendation

Berikut adalah rekomendasi data model berdasarkan schema yang ada, dengan tambahan kolom dan tabel yang diperlukan untuk memenuhi requirement.

10.1 Tabel Utama & Rekomendasi Perubahan

Entitas	Kolom Kunci	Rekomendasi Perubahan
users	id, username, password_hash, role, is_active, department_id, created_at, last_login_at, locked_until	Tambah: locked_until (DATETIME nullable) untuk account lockout Tambah: failed_login_count (INT DEFAULT 0) Tambah: department_id (FK) untuk role department
prospects	id, created_by_user_id, customer_id, name, description, status, tambahan_question_checklist (JSON), approved_by, approved_at, revisi_catatan, created_at, updated_at	Tambah: assigned_pm_id (FK users) untuk tracking PM yang mereview Tambah: deleted_at (DATETIME nullable) untuk soft delete
projects	id, prospect_id (FK nullable), customer_id, type, status, pm_approved_by, pm_approved_at, tender_data (JSON), department_approvals (JSON), lphs_data (JSON), harga_data (JSON), competitors (JSON), pemenang_data (JSON), target_delivery (JSON), review_questions (JSON), created_by, created_at, updated_at	Tambah: deleted_at (DATETIME nullable) untuk soft delete Tambah: deadline_tender (DATE, indexed) untuk query dashboard approaching deadline Pertimbangkan normalisasi department_approvals ke tabel terpisah jika query analitik diperlukan
approvals	id, entity_type (prospect/project), entity_id, step, decision, decided_by, decided_at, notes, created_at	Sudah baik; pastikan ada INDEX pada (entity_type, entity_id, step) untuk query cepat
timeline_events	id, project_id, event_type, description, actor_id, created_at	Tambah: metadata (JSON nullable) untuk menyimpan detail tambahan per event type
audit_logs	id, user_id, action, entity_type, entity_id, payload_before (JSON), payload_after (JSON), ip_address, user_agent, created_at	Tambah: payload_before dan payload_after untuk delta tracking Tambah: ip_address dan user_agent untuk forensik
documents	id, project_id, document_type, original_filename, stored_filename, file_size,	Tabel baru: melacak semua dokumen yang diupload per proyek dengan versioning

Entitas	Kolom Kunci	Rekomendasi Perubahan
	mime_type, uploaded_by, version, created_at	Memisahkan metadata dokumen dari JSON proyek
notifications	id, user_id, type, title, message, entity_type, entity_id, is_read, created_at	Tabel baru: untuk fitur notifikasi in-app
question_type_defs	id, name, config (JSON), is_default, created_by, created_at	Tabel baru: migrasi dari localStorage. Menyimpan definisi tipe pertanyaan custom secara persisten di DB

10.2 Indeks yang Direkomendasikan

Tabel	Kolom (Index)	Tujuan
projects	status, created_at	Filter dashboard per status
projects	customer_id	Join ke master customer
projects	created_by	Filter per cabang
prospects	status, created_by	Daftar prospek per cabang dan status
approvals	entity_type, entity_id, step	Lookup approval cepat
timeline_events	project_id, created_at	Timeline query per proyek
audit_logs	user_id, created_at	Audit log per user
notifications	user_id, is_read, created_at	Notifikasi pending per user

11. API Recommendation

Semua endpoint menggunakan prefix `/backend/api/` dengan Content-Type: `application/json`. Autentikasi via Bearer token di header Authorization.

Endpoint	Method	Role	Tujuan
<code>/auth/login</code>	POST	Semua	Autentikasi, mengembalikan token
<code>/auth/logout</code>	POST	Semua	Invalidasi session/token
<code>/auth/me</code>	GET	Semua	Get profil user saat ini
<code>/auth/change-password</code>	PUT	Semua	Ganti password
<code>/users</code>	GET	Admin	List semua user
<code>/users</code>	POST	Admin	Buat user baru
<code>/users/{id}</code>	PUT	Admin	Update data/role/status user
<code>/users/{id}</code>	DELETE	Admin	Soft-delete (deactivate) user
<code>/prospects</code>	GET	cabang, pm, admin	List prospek (filter: status, cabang)
<code>/prospects</code>	POST	Cabang	Buat prospek baru
<code>/prospects/{id}</code>	GET	cabang, pm, admin	Detail prospek
<code>/prospects/{id}</code>	PUT	Cabang	Update prospek (jika draft/revision)
<code>/prospects/{id}/submit</code>	POST	Cabang	Submit ke PM
<code>/prospects/{id}/approve</code>	POST	PM	Approve prospek
<code>/prospects/{id}/revise</code>	POST	PM	Kirim revisi prospek
<code>/prospects/{id}/answer</code>	POST	Cabang	Jawab revisi PM
<code>/prospects/{id}</code>	DELETE	Cabang, Admin	Hapus prospek (cascade)

Endpoint	Method	Role	Tujuan
/projects	GET	Semua (scope per role)	List proyek
/projects	POST	Cabang	Buat proyek baru
/projects/{id}	GET	Semua (scope per role)	Detail proyek + timeline
/projects/{id}/rks	PUT	Cabang	Update / submit RKS
/projects/{id}/rks/approve	POST	PM	Approve RKS
/projects/{id}/rks/revise	POST	PM	Revisi RKS
/projects/{id}/dept-approval	PUT	Dept, PM	Update approval departemen atau PM di RKS
/projects/{id}/lphs	PUT	Cabang, PM, Dept, Mgmt	Update LPHS/SIOS sesuai role
/projects/{id}/lphs/approve	POST	Managem ent	Final approve LPHS
/projects/{id}/lphs/revise	POST	Managem ent	Revisi LPHS
/projects/{id}/harga	PUT	Cabang	Update harga penawaran
/projects/{id}/kompetitor	PUT	Cabang	Update kompetitor
/projects/{id}/pemenang	PUT	Cabang	Input hasil tender
/projects/{id}/delivery	PUT	Cabang	Input target delivery
/documents/upload	POST	Cabang (scope proyek)	Upload dokumen (multipart/form-data)
/documents/{id}/download	GET	Semua (scope proyek)	Download dokumen (stream)
/documents/{id}	DELETE	Cabang, Admin	Hapus dokumen (soft)
/dashboard/summary	GET	Semua	Data ringkasan sesuai role

Endpoint	Method	Role	Tujuan
/dashboard/pipeline	GET	mgmt, admin	Data pipeline value dan trend
/master/customers	GET/POST/PUT/DELETE	Admin	CRUD customer
/master/departments	GET/POST/PUT/DELETE	Admin	CRUD department
/master/questions	GET/POST/PUT/DELETE	Admin	CRUD pertanyaan master
/master/question-types	GET/POST/PUT/DELETE	Admin	CRUD tipe pertanyaan (migrasi dari localStorage)
/notifications	GET	Semua	List notifikasi user saat ini
/notifications/{id}/read	PUT	Semua	Tandai notifikasi dibaca
/notifications/read-all	PUT	Semua	Tandai semua dibaca
/audit-logs	GET	Admin	List audit log (filter: user, tanggal, entity)
/audit-logs/export	GET	Admin	Export audit log CSV
/health	GET	Semua (tanpa auth)	Health check untuk Docker & monitoring

12. QA Test Scenarios

12.1 Autentikasi

TC-ID	Skenario	Input	Expected Result	Tipe
TC-A01	Login dengan kredensial valid	username dan password benar	Login berhasil, redirect ke dashboard sesuai role	Positif
TC-A02	Login dengan password salah	password tidak sesuai	Error 'Username atau password salah', login diblokir	Negatif
TC-A03	Account lockout setelah 5 kali gagal	5x password salah berturututan	Akun terkunci 15 menit, pesan ditampilkan	Edge
TC-A04	Akses halaman tanpa login	Buka URL dashboard langsung	Redirect ke halaman login	Negatif
TC-A05	Session timeout setelah idle	Tidak ada aktivitas 30 menit	Session expired, redirect ke login	Edge
TC-A06	User dinonaktifkan mencoba login	User is_active=0 mencoba login	Error 'Akun tidak aktif'	Negatif

12.2 Manajemen Prospek

TC-ID	Skenario	Input	Expected Result	Tipe
TC-P01	Cabang membuat prospek valid	Semua field required diisi	Prospek tersimpan dengan status 'prospecting'	Positif
TC-P02	Submit prospek tanpa nama	Nama dikosongkan	Validasi error 'Nama wajib diisi'	Negatif
TC-P03	Submit ke PM dengan pertanyaan required belum terjawab	Ada pertanyaan required kosong	Submit diblokir, validasi error per field	Negatif
TC-P04	PM approve prospek valid	Prospek dalam status waiting_pm_approval	Status berubah ke 'approved', timeline event dibuat	Positif
TC-P05	PM revision dengan catatan	PM mengisi review questions	Status berubah ke 'revision', cabang mendapat notifikasi	Positif
TC-P06	Cabang melihat prospek cabang lain	Akses URL prospek milik cabang berbeda	403 Forbidden atau data tidak tampil	Keamanan

TC-ID	Skenario	Input	Expected Result	Tipe
TC-P07	Hapus prospek yang sudah punya proyek	Hapus prospek dengan project terkait	Konfirmasi cascade delete, hapus prospek+proyek	Edge

12.3 Alur Tender

TC-ID	Skenario	Input	Expected Result	Tipe
TC-T01	Submit RKS dengan data lengkap	Semua field RKS terisi	Status berubah ke 'submit_rks', timeline event dibuat	Positif
TC-T02	PM approve RKS dengan pertanyaan review belum terjawab	reviewQuestions ada yang kosong	Backend menolak approve, error ditampilkan	Negatif
TC-T03	Management approve LPHS sebelum semua dept approve	Ada dept yang belum approve	Backend menolak, error 'Semua departemen harus setuju'	Negatif
TC-T04	Management approve LPHS dengan semua dept dan PM approve	Semua pre-condition terpenuhi	Status berubah ke 'submit_harga', record di approvals dibuat	Positif
TC-T05	Cabang proyek B mencoba edit proyek A	Access proyek milik cabang lain	403 Forbidden	Keamanan
TC-T06	Transition status tidak valid (skip step)	API call langsung ke status 'selesai' dari 'submit_rks'	Backend menolak, status tidak berubah	Keamanan
TC-T07	Proyek non-tender melewati tahap RKS	Proyek type=prospecting	Tahap RKS, dept review, LPHS tidak muncul di UI dan backend tidak menerima call tersebut	Edge
TC-T08	Upload dokumen tipe file tidak diizinkan	Upload file .exe	Ditolak dengan pesan error tipe file	Negatif
TC-T09	Upload dokumen melebihi 25 MB	File 30 MB	Ditolak dengan pesan error ukuran file	Negatif
TC-T10	Download dokumen tanpa akses proyek	User tanpa akses mencoba download	403 Forbidden	Keamanan
TC-T11	Timeline proyek menampilkan	Proyek dengan 10+ event	Timeline tampilurut ASC, semua event ada	Positif

TC-ID	Skenario	Input	Expected Result	Tipe
	semua event secara kronologis			

12.4 Docker & Deployment

TC-ID	Skenario	Expected Result	Tipe
TC-D01	docker-compose up berhasil menjalankan semua service	Frontend, backend, DB semua UP tanpa error	Infrast ruktur
TC-D02	Data MySQL persisten setelah container restart	docker-compose restart → data proyek masih ada	Infrast ruktur
TC-D03	File upload persisten setelah container restart	Restart → file yang diupload sebelumnya masih bisa didownload	Infrast ruktur
TC-D04	Endpoint health check mengembalikan status OK	GET /backend/health.php → 200 OK dengan status DB: connected	Infrast ruktur
TC-D05	Aplikasi berjalan dengan env variable dari .env	.env berisi DB credentials → backend terhubung ke DB	Infrast ruktur
TC-D06	Frontend dapat berkomunikasi dengan backend dalam Docker network	API call dari frontend container ke backend container berhasil	Infrast ruktur

13. Risks & Assumptions

13.1 Risks

Risk ID	Deskripsi Risiko	Probabilitas	Dampak	Mitigasi
R-01	Data JSON di kolom DB sulit di-query untuk analitik kompleks (misal: win rate per departemen yang mereview)	Tinggi	Medium	Normalisasi department_approvals ke tabel terpisah; atau tambahkan materialized view/reporting table
R-02	Inkonsistensi antara state di frontend (AppContext) dan state di backend jika ada error mid-action	Medium	Tinggi	Selalu reload data dari server setelah setiap mutasi; jangan andalkan state UI sebagai source of truth
R-03	Question type definitions di localStorage menyebabkan data tidak konsisten antar browser/user	Tinggi	Medium	Prioritaskan migrasi ke tabel question_type_defs di DB (FR-102)
R-04	File upload yang besar menyebabkan timeout di PHP dengan default config	Medium	Medium	Set upload_max_filesize, post_max_size, max_execution_time di Docker PHP config
R-05	Tidak ada mekanisme re-assign approval jika PM/dept user tidak aktif	Medium	Tinggi	Tambahkan fitur re-assign approval oleh admin sebagai escape hatch
R-06	Race condition jika dua user approve/revisi entitas yang sama bersamaan	Rendah	Tinggi	Implementasi optimistic locking: cek updated_at sebelum commit, tolak jika berubah
R-07	Kualitas kode backend PHP tidak konsisten (campuran gaya, raw SQL vs prepared)	Medium	Medium	Code review + enforced coding standard, migrasi ke prepared statements penuh

13.2 Assumptions

- Sistem hanya digunakan di lingkungan intranet perusahaan; tidak perlu diakses dari internet publik.
- Satu user hanya memiliki satu role aktif (tidak ada multi-role per user).
- Email notifikasi eksternal (SMTP) tersedia jika fitur notifikasi email diimplementasikan di fase 2.
- Infrastructure Docker berjalan di server Linux (Ubuntu 22.04 LTS atau setara).
- Browser yang didukung: Chrome 110+, Firefox 110+, Edge 110+.
- Data awal (seed) master customer, departemen, dan pertanyaan akan disediakan oleh tim bisnis sebelum go-live.

- Cadangan (fallback) data statis di `src/store/data.ts` hanya digunakan untuk development, tidak untuk production.

14. Improvement Recommendations

Bagian ini mencatat kritik konstruktif terhadap desain dan implementasi saat ini, serta rekomendasi perbaikan berbasis pertimbangan bisnis dan teknis.

14.1 Kritik Terhadap Desain Saat Ini

[Kritikal] JSON Blob sebagai Database Relasional

Menyimpan `department_approvals`, `lphs_data`, `tender_data` sebagai JSON longtext di satu kolom `projects` menghasilkan sistem yang sulit di-query, sulit untuk reporting, dan rawan korupsi data jika ada bug serialisasi.

Rekomendasi

Normalisasi `department_approvals` ke tabel `project_department_approvals(id, project_id, department_id, status, notes, decided_by, decided_at)`. Ini memungkinkan query 'proyek mana yang masih pending approval dari Departemen X' secara efisien.

[Kritikal] State UI ≠ Source of Truth Backend

`AppContext.tsx` menyimpan state aplikasi di memori dan hanya sinkron dengan backend pada aksi tertentu. Jika ada kegagalan jaringan antara UI update dan API call, state UI bisa inconsistent dengan DB.

Rekomendasi

Setelah setiap mutasi berhasil di backend, lakukan re-fetch data proyek dari server dan update state. Jangan update state UI secara optimistic untuk operasi kritis seperti approval. Pertimbangkan React Query atau SWR untuk cache management yang lebih robust.

[Kritikal] localStorage untuk Question Types

`MasterPertanyaanPage` menggunakan `localStorage` untuk menyimpan definisi tipe pertanyaan custom. Ini berarti data tidak tersinkron antar user, tidak persisten lintas browser, dan hilang jika browser history dihapus.

Rekomendasi

Implementasikan tabel `question_type_defs` di DB dan endpoint CRUD-nya. Ini adalah FR-102 dengan prioritas Must Have.

[Tinggi] Tidak Ada Escape Hatch untuk Stuck Workflows

Jika PM atau departemen yang harus meng-approve tidak aktif (resign, sakit panjang), proyek akan stuck tanpa cara untuk melanjutkan.

Rekomendasi

Tambahkan fitur 'Re-assign Approval' yang hanya bisa dilakukan admin: memindahkan kewajiban approval dari user A ke user B. Semua re-assign harus dicatat di audit log.

[Tinggi] Tidak Ada Notifikasi

Saat ini tidak ada mekanisme notifikasi. Semua pihak harus aktif mengecek sistem untuk mengetahui apakah ada item yang perlu diaksi. Ini meningkatkan waktu approval secara signifikan.

Rekomendasi

Fase 1: notifikasi in-app dengan badge counter (FR-090, FR-091). Fase 2: email notifikasi untuk deadline approaching dan approval pending. Implementasikan notification queue di DB (tabel notifications).

[Medium] Tidak Ada Versi Dokumen

Jika cabang mengunggah ulang dokumen yang sama (misal revisi RKS), tidak jelas apakah file lama digantikan atau disimpan. Ini berpotensi kebingungan di reviewer yang sudah melihat versi sebelumnya.

Rekomendasi

Implementasikan tabel documents dengan field version_number. Upload ulang tidak menghapus file lama tetapi menambah versi baru. Reviewer dapat melihat semua versi.

[Medium] Race Condition pada Approval

Jika dua orang (misal dua PM dalam skenario future) melakukan approve pada saat bersamaan, keduanya bisa berhasil meskipun seharusnya hanya satu yang boleh. Ini juga berlaku untuk transition status.

Rekomendasi

Implementasikan optimistic locking: sertakan updated_at dalam payload PUT/POST. Backend menolak jika updated_at di DB berbeda (artinya ada update lain yang lebih dulu). Kembalikan 409 Conflict ke client.

[Medium] Kurangnya API Versioning

Backend saat ini menggunakan file PHP langsung (/backend/prospects.php) tanpa versioning API. Jika ada breaking change di masa depan, semua client harus diupdate bersamaan.

Rekomendasi

Reorganisasi ke struktur /backend/api/v1/prospects/. Saat ini tidak kritis untuk internal app, tetapi sebaiknya dilakukan sebelum sistem berkembang lebih besar.

[Medium] Deployment Docker Belum Terdefinisi

Informasi prototype menyebutkan akan pakai Docker, namun belum ada docker-compose.yml, Dockerfile untuk frontend dan backend, serta konfigurasi nginx/apache.

Rekomendasi

Buat: (1) Dockerfile untuk frontend (Nginx serve Vite build), (2) Dockerfile untuk backend PHP (php:8.2-fpm + nginx), (3) docker-compose.yml yang mengorkestrasikan ketiganya + MySQL + volumes + health checks. Tambahkan .env.example sebagai template konfigurasi.

14.2 Peluang Peningkatan Nilai Bisnis

Ide	Nilai Bisnis	Kompleksitas	Prioritas
Laporan Win/Loss Analysis dengan filter alasan kekalahan	Membantu strategi tender berikutnya berdasarkan data historis	Rendah	Should Have
Export data proyek ke Excel/CSV	Memudahkan reporting ke level yang tidak menggunakan sistem	Rendah	Should Have
Deadline reminder otomatis (T-7, T-3, T-1 hari)	Mencegah miss deadline tender secara proaktif	Medium	Should Have
Fitur komentar/diskusi dalam proyek (thread)	Menggantikan komunikasi via WhatsApp/email untuk konteks proyek	Medium	Could Have
Approval via link email (one-click approve)	Mempercepat approval untuk management yang sibuk	Medium	Could Have
Dashboard executive real-time (TV mode)	Visibility di ruang meeting/kantor tanpa login	Rendah	Could Have
Integrasi SSO (Active Directory / Google)	Menghilangkan manajemen password terpisah	Tinggi	Fase 2

Appendix A: Rekomendasi Struktur Docker

Berikut adalah gambaran arsitektur Docker yang direkomendasikan untuk project ini:

A.1 Service yang Diperlukan

Service	Image Dasar	Port	Keterangan
frontend	node:20-alpine (build) → nginx:alpine (serve)	80:80	Vite build di-serve via Nginx. Proxy /backend/ ke service backend
backend	php:8.2-fpm + nginx	9000 (internal)	PHP-FPM + Nginx untuk serve /backend/*.php
db	mysql:8.0	3306 (internal)	MySQL database. Port tidak diekspos ke host di production
db-backup	Cron container	-	Opsional: daily mysqldump ke volume backup

A.2 Volume yang Diperlukan

Volume	Mount Point	Tujuan
mysql_data	/var/lib/mysql	Persistensi data MySQL
upload_data	/var/www/html/backend/uploads	Persistensi file upload (dokumen tender)
backup_data	/backups	Opsional: lokasi mysqldump harian
php_logs	/var/log/php	Log error PHP untuk debugging

A.3 Environment Variables (.env)

Variable	Contoh Nilai	Keterangan
DB_HOST	db	Nama service MySQL di Docker network
DB_PORT	3306	Port MySQL
DB_NAME	sales_tender_db	Nama database
DB_USER	app_user	User DB (bukan root)
DB_PASSWORD	ChangeMe123!	Password DB — jangan hardcode di source
JWT_SECRET	randomly-generated-64-char-string	Secret untuk signing JWT token

Variable	Contoh Nilai	Keterangan
APP_ENV	production / development	Mode aplikasi
UPLOAD_MAX_SIZE_MB	25	Batas ukuran upload dalam MB
SESSION_TIMEOUT_MINUTES	30	Timeout idle session

A.4 Health Check Recommendations

- MySQL: healthcheck menggunakan mysqladmin ping dengan interval 10s, timeout 5s, retries 5.
- Backend: healthcheck menggunakan GET /backend/health.php yang mengembalikan 200 jika DB connected.
- Frontend: healthcheck menggunakan wget --quiet --tries=1 http://localhost/.
- depends_on dengan condition: service_healthy memastikan backend tidak start sebelum DB siap.

— Akhir Dokumen PRD —

Sales & Tender Management System v1.0 | Confidential